

```
PS:\> terraform apply -auto-approve
```

redStack:

Boot-to-Breach Red Team Platform



DEF CON 34 • Noob Village

Saturday, Aug 8 • 1:00-2:50pm • 2-hour hands-on

Instructors: Mike Ortiz • Michael Kim



KEEP
CALM
the
RED TEAM
IS HERE



```
sliver > whoami
```

whoami²

Your instructors

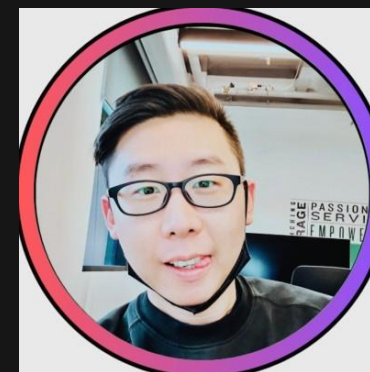


Mike Ortiz

- > Red Team Engineer / SME · Red Cell, U.S. Dept. of State
- > U.S. Marine Corps veteran · SSgt (E-6) · 12 years
- > 25+ years in IT, network engineering, and cyber operations
- > Founder, devZero Security (SDVOSB) · offensive security and cybersecurity engineering

Michael Kim

Offensive Security, Red Team · Mandiant (part of Google Cloud) <
Offensive Security Consultant · Adversary Simulation <
Security Researcher · CVE Contributor (3 CVEs) <
Active Directory · Cloud · AI Offensive Security <



```
$ man red-team
```

Red Teaming 101

Emulate a real adversary.

End to end, against a defended target.

A pentest counts vulnerabilities. A red team tests whether the target detects and responds, and gauges the blast radius of not if they get breached, but when.

Everything in this project exists to run this workflow.

01

The attack chain

Recon, initial access, execution, C2, privilege escalation, objective.

02

Command and control

A beacon on the target calls back to operator infrastructure to run tasks and move.

03

Redirectors and OPSEC

Front your C2 behind infrastructure that validates traffic and hides the team server.

04

Evasion and tradecraft

Blend C2 with normal traffic: CDN-style URIs, header tokens, decoy pages.

05

Multi-C2 segmentation

Run several C2s in parallel, each behind its own redirector path. Burn one, the others hold.

```
$ git clone redStack && terraform init
```

What is redStack?

One terraform apply. Full red team lab. Boot-to-Breach.

One terraform apply

01

Full stack in 5 to 10 min. terraform destroy tears it down. Fully repeatable.

Three C2 frameworks

02

Mythic, Sliver, and Havoc. Internal only, no public IPs.

Apache redirector

03

X-Request-ID validation and CDN-style URI routing. Decoy page for invalid traffic.

Operator hosts

04

Windows Server 2022 workstation and a Kali box with AD tooling on demand.

Guacamole portal

05

Browser-based RDP and SSH to every host. No local clients needed.

Tunneled access

06

OpenVPN and WireGuard route the lab to cyber ranges (Hack Smarter Labs).

```
$ terraform output network_architecture
```

Architecture: Tunnelled Access

Two peered VPCs. The redirector is the OpenVPN gateway. Beacons call back to the redirector public EIP over 443.

Teamserver VPC 10.50.0.0/16

Mythic · Sliver · Havoc · Guacamole · Windows · Kali. No public IPs.

Redirector VPC 10.60.0.0/16

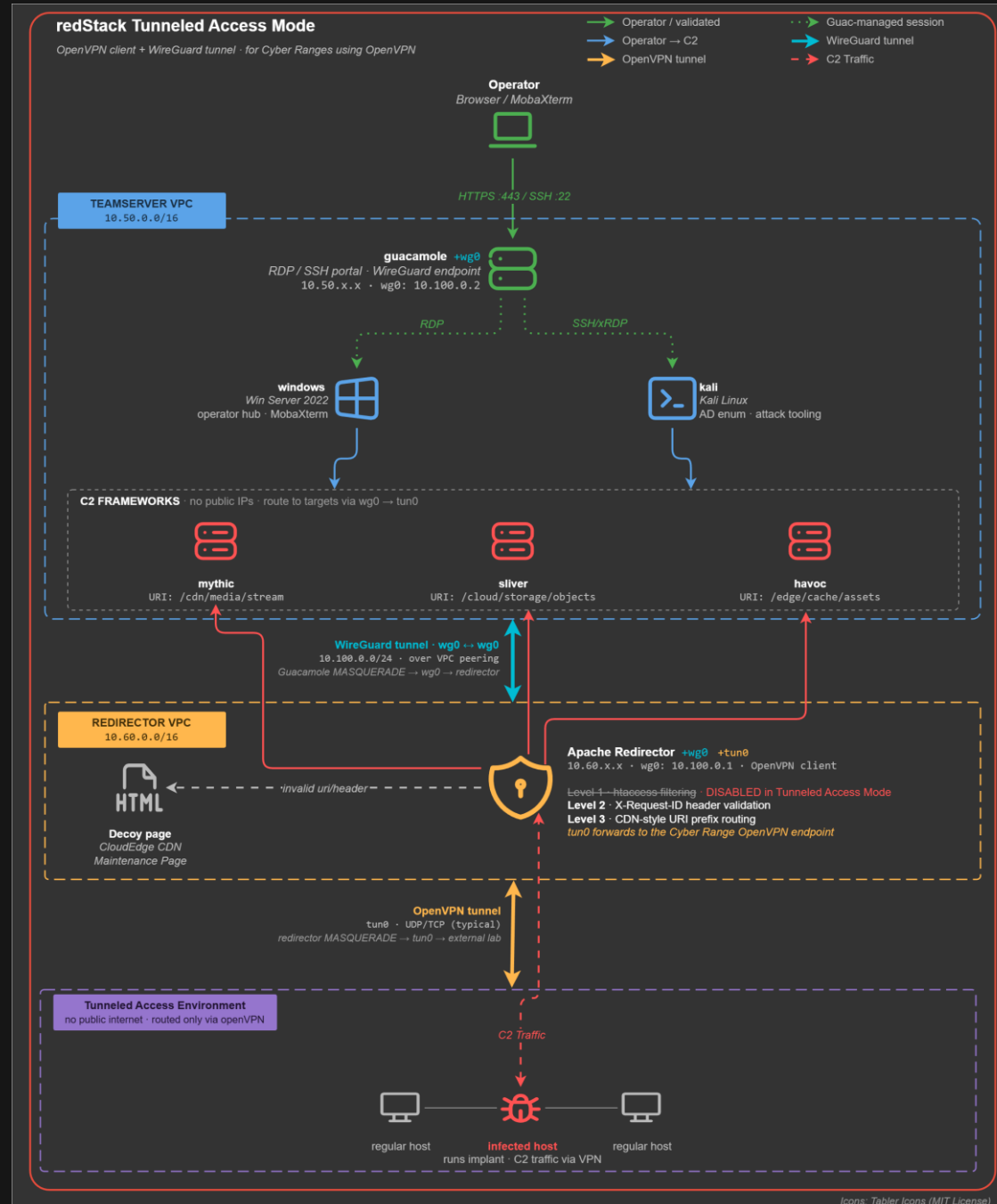
Public Elastic IP plus the OpenVPN client (tun0).

WireGuard 10.100.0.0/24

Bridges VPC peering to the tunnel. Targets sit outside both VPC CIDRs.

C2 callback

Beacons hit the redirector public EIP over HTTPS / 443. The public-EIP gotcha.



```
$ nano 0_PREREQ.md
```

Prerequisites

Do this BEFORE the session. One-time per AWS account (about 15 to 30 min). Do not burn the workshop clock.

- ✓ Dedicated, throwaway AWS account (payment method attached)
- ✓ AWS CLI configured · IAM AdministratorAccess · region us-east-1
- ✓ Terraform 1.0+ and Git installed
- ✓ Kali Linux Marketplace EULA accepted
- ✓ Hack Smarter Labs account · ShadowGate enrolled · .ovpn downloaded
- ✓ redStack repo cloned
- ✓ SSH key pair rs-rsa-key created in AWS (.pem in repo root)
- ✓ Public IPv4 recorded · CloudWatch billing alarm set



Scan to clone the workshop repo

github.com/BaddKharma/redStack-defcon34

Same repo holds 0_PREREQ + the three run guides

Budget ~\$2 to \$3 AWS spend · ~\$0.27 / hr compute · run terraform destroy when you finish.

```
$ cat AGENDA.md
```

Run of show

Two hours, hands-on. Prereqs are done before the session.

10 min

Intro

Prereqs confirmed. Frame the multi-C2 segmentation pattern.

30 min

Deploy

Stand up the stack from one terraform apply, narrated live. Tunnel up.

30 min

Config

Stand up Sliver, Mythic, and Havoc behind the redirector. Test each.

5 min

Break

Stretch. The stack keeps running.

25 min

Attack path (live range)

Sliver in first, Mythic and Havoc staged through it, then SYSTEM.

10 min

Q&A + teardown

terraform destroy to stop the meter. One-on-ones after.

Attack chain: ShadowGate

Push in over the tunnel. The beacon calls back over the public EIP. Both paths must work.

1

Recon

From Kali, over the tunnel: nmap DC01.shadow.gate. Map SMB, Kerberos, LDAP, AD CS.

2

Domain compromise (whitecarded)

Skip the 40-minute AD chain. Start from the Administrator NT hash.

3

Land the Sliver beacon

Pass-the-hash: disable Defender, upload the implant, execute. Callback hits the redirector public EIP.

4

Stage Mythic + Havoc

Push Apollo and the Havoc demon through the Sliver beacon. All three land as Administrator.

5

Escalate to SYSTEM

schtasks /ru SYSTEM runs the dropped beacon (not getsystem). getuid returns S-1-5-18.

6

Bonus + teardown

SYSTEM in Mythic and Havoc via Selmpersonate, then terraform destroy.


```
$ tail -f redirector-ssl-access.log
```

Gotchas

The failure points we hit while testing. Symptom on the left, fix on the right.

SYMPTOM

FIX

Beacon never calls back

Callback must hit the redirector public EIP on 443, never the tun0 IP.

getsystem returns no session

Expected on DC's. Use schtasks /ru SYSTEM on the dropped beacon.

Windows path lands mangled

Sliver execute escapes backslashes. Double them, and run commands one at a time.

Staged payload vanishes

Disable Defender realtime before upload: Set-MpPreference -DisableRealtimeMonitoring 1.

Redirector serves a decoy 200

Bad header or URI prefix. No hit in the redirector log means it never reached the EIP.

terraform apply fails on Kali

Marketplace EULA not accepted (OptInRequired). Accept it during prereqs.

```
demon » inline-execute
```

DEMO TIME

Boot to breach: deploy, stand up C2, land a Sliver beacon on ShadowGate, escalate to SYSTEM.

REDTEAM MODE: ENGAGED



Follow along: github.com/BaddKharma/redStack-defcon34

```
./mythic-cli status
```

Questions

Contact us. Scan a code to connect with your instructors.

Mike Ortiz



 BaddKharma

Michael Kim



 mssvmssv
 mssv.mssv

Slides and guides: github.com/BaddKharma/redStack-defcon34